

作业：安全审查与加固

作业目标

用 AI 辅助（Vibe Coding 工作流）对项目进行安全审查，发现并修复安全漏洞，并在 CI 中集成至少一项自动化安全扫描。

第一步：AI 辅助安全审查（必做）

将项目的核心后端代码（接口、数据库操作、认证相关）提交给 AI 做安全审查。

推荐 Prompt（复制使用）：

请对以下代码进行安全审查（OWASP Top 10 视角）：

检查内容：

1. 注入漏洞（SQL / 命令注入）
2. 失效的访问控制（未鉴权的接口）
3. 硬编码密钥或敏感信息
4. 密码是否明文存储
5. 错误信息是否暴露内部细节

对每个发现的问题：

- 说明漏洞类型和危害等级（高/中/低）
- 提供修复后的完整代码

[粘贴代码]

要求：

- 记录 AI 发现的问题（截图或复制到文档）
 - 对至少 2 处有意义的问题进行修复并提交代码
 - 在 `docs/security-review.md` 中记录审查过程和结论
-

第二步：安全检查清单（按项目情况完成）

根据项目实际情况，完成以下检查。不强制全部完成，但每项都应说明是否适用及处理方式：

认证与授权

- ☐ 密码存储：使用 bcrypt / argon2 哈希，不存明文
- ☐ JWT / Session：token 有过期时间，logout 后失效

- ☐ 接口鉴权：所有需要登录的接口都有权限校验
- ☐ 越权访问：用户只能操作自己的数据（不能通过改 ID 访问他人数据）

注入防护

- ☐ SQL：使用 ORM 或参数化查询，无字符串拼接 SQL
- ☐ XSS：前端输出用户数据时不用 `innerHTML`，或使用 `DOMPurify`

敏感信息

- ☐ API Key / 密码：不硬编码在代码中，通过环境变量读取
- ☐ `.env` 文件：已加入 `.gitignore`，仓库中有 `.env.example`

依赖安全

- ☐ 运行依赖扫描，无高危漏洞（或已记录已知漏洞原因）

第三步：CI 自动化安全扫描（必做，选一项）

在 GitHub Actions 中集成至少 一项 自动化安全扫描：

选项 A：密钥泄露扫描（推荐，最简单）

```
# .github/workflows/security.yml
name: Security Scan
on: [push, pull_request]

jobs:
  gitleaks:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
        with:
          fetch-depth: 0
      - uses: gitleaks/gitleaks-action@v2
```

选项 B：依赖漏洞扫描

```
# Node.js 项目：在 CI 中运行
npm audit --audit-level=high

# Python 项目：
pip install pip-audit
pip-audit
```

```
# GitHub Actions 中
- name: 依赖安全扫描
  run: npm audit --audit-level=high
# 或: pip-audit
```

选项 C : GitHub 原生安全功能（零配置）

在仓库 Settings → Security 中启用：

- **Dependabot alerts**：自动扫描依赖漏洞
- **Secret scanning**：自动检测提交中的密钥

截图展示已启用即可。

选做：进阶安全加固

以下内容自由选做，每完成一项额外加分：

选做项	说明
登录失败限频	同一 IP/账号 5 次失败后锁定 10 分钟
安全 HTTP 头	配置 CSP、X-Frame-Options、HSTS 等响应头
CSRF 保护	状态变更接口添加 CSRF Token
速率限制	API 接口添加 rate limiting
CodeQL 扫描	配置 GitHub CodeQL 静态分析
Prompt 注入防护	若项目有 AI 功能，添加输入净化和注入检测

提交内容

Git 仓库提交

1. 修复代码：安全审查后修复的漏洞
2. **docs/security-review.md**：AI 审查记录，包含发现的问题和处理方式
3. **.github/workflows/security.yml**（或截图证明启用了 GitHub 安全功能）
4. **.env.example**：密钥配置模板（如果项目有 API Key）
5. **docs/contributions/10-security/你的名字.md**：个人贡献说明

学习通提交（截图）

1. Git 提交记录：`git log --author="YOUR_NAME" --oneline` 终端截图
2. AI 审查截图：与 AI 的安全审查对话截图（至少 1 张）
3. CI 安全扫描通过截图：GitHub Actions 运行成功的截图

个人贡献说明

每位成员在 docs/contributions/10-security/ 下提交：

文件名：你的名字.md

内容模板：

```
# 安全审查贡献说明

姓名：XXX
学号：XXX
日期：XXXX-XX-XX

## 我完成的工作

### AI 安全审查
- 审查了哪些文件/模块：
- AI 发现的主要问题：
- 我修复了哪些问题：

### 安全检查清单
（复制第二步清单，勾选已完成项，未适用项注明原因）

### CI 安全扫描
- 配置了哪个选项（A/B/C）：
- 扫描结果：

### 选做完成情况
- （如有）

## PR 链接

- PR #X: https://github.com/xxx/xxx/pull/X

## 遇到的问题和解决

1. 问题：
   解决：

## 心得体会

（Vibe Coding 场景下，如何平衡开发效率和安全？）
```

评分标准

项目	分值	说明
AI 安全审查	30%	有完整的审查记录，至少修复 2 处
安全检查清单	25%	逐项说明状态，适用项已处理
CI 安全扫描	25%	成功集成并在 CI 中通过
个人贡献说明	20%	内容具体，有截图佐证
选做加分	+10%	每完成一项额外加分

💡 **提示：**没有漏洞也是好结果，重要的是**过程**——用 AI 认真审查、如实记录、养成安全开发习惯。